CHAPITRE 2_TP 2.1: AUDIT DE VULNÉRABILITÉS AVEC NESSUS

Environnement : Kali Linux (Machine attaquante), Windows, Ubuntu (Cibles)

L'objectif de ce TP est de mettre en œuvre une solution d'audit de sécurité réseau pour identifier les vulnérabilités présentes sur deux machines cibles. Nous utilisons Nessus Essentials, un scanner de vulnérabilités de référence, installé sur une instance Kali Linux.

I-Méthodologie et Mise en œuvre

1-Installation et initialisation de Nessus

Après l'installation du paquet Nessus, le service a été activé via la commande ***systemctl start nessusd.*** L'accès à l'interface s'est fait via l'URL https://localhost:8834. Une phase cruciale de compilation des plugins a été nécessaire pour mettre à jour la base de données des signatures d'attaques

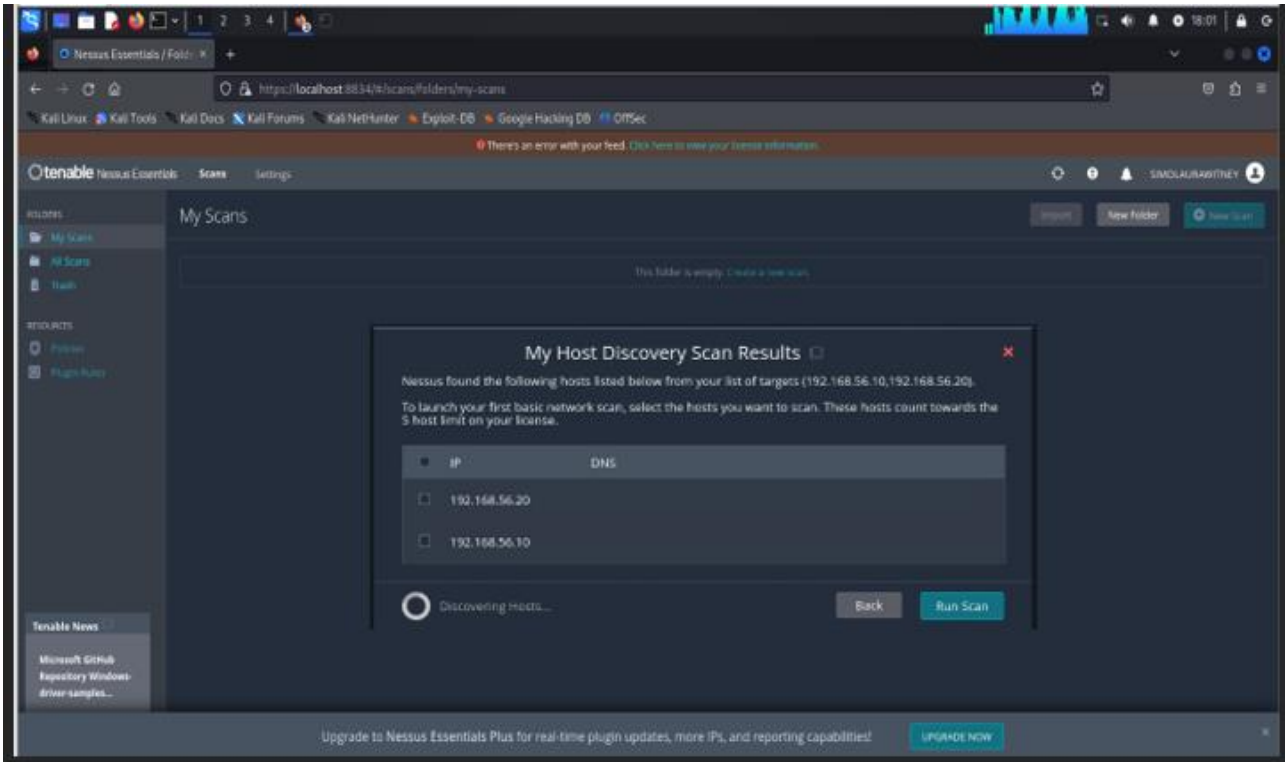
```
┌──(laurasimo㉿laura)-[~/Downloads]
└─$ sudo dpkg -i Nessus-10.11.3-ubuntu1604_amd64.deb
(Reading database ... 404068 files and directories currently installed.)
Preparing to unpack Nessus-10.11.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.11.3) over (10.11.3) ...
Setting up nessus (10.11.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

 - You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
 - Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner


┌──(laurasimo㉿laura)-[~/Downloads]
└─$
```

2-Phase de découverte (Host Discovery)

Avant de lancer l'analyse profonde, une recherche a été effectuée sur la plage réseau 192.168.56.0/24 pour identifier les machines actives.



D'après la figure ci-dessus, nous avons détecté deux hôtes : 192.168.56.20 (Windows) et 192.168.56.10 (Ubuntu).

3-Configuration de l'audit (Basic Network Scan)

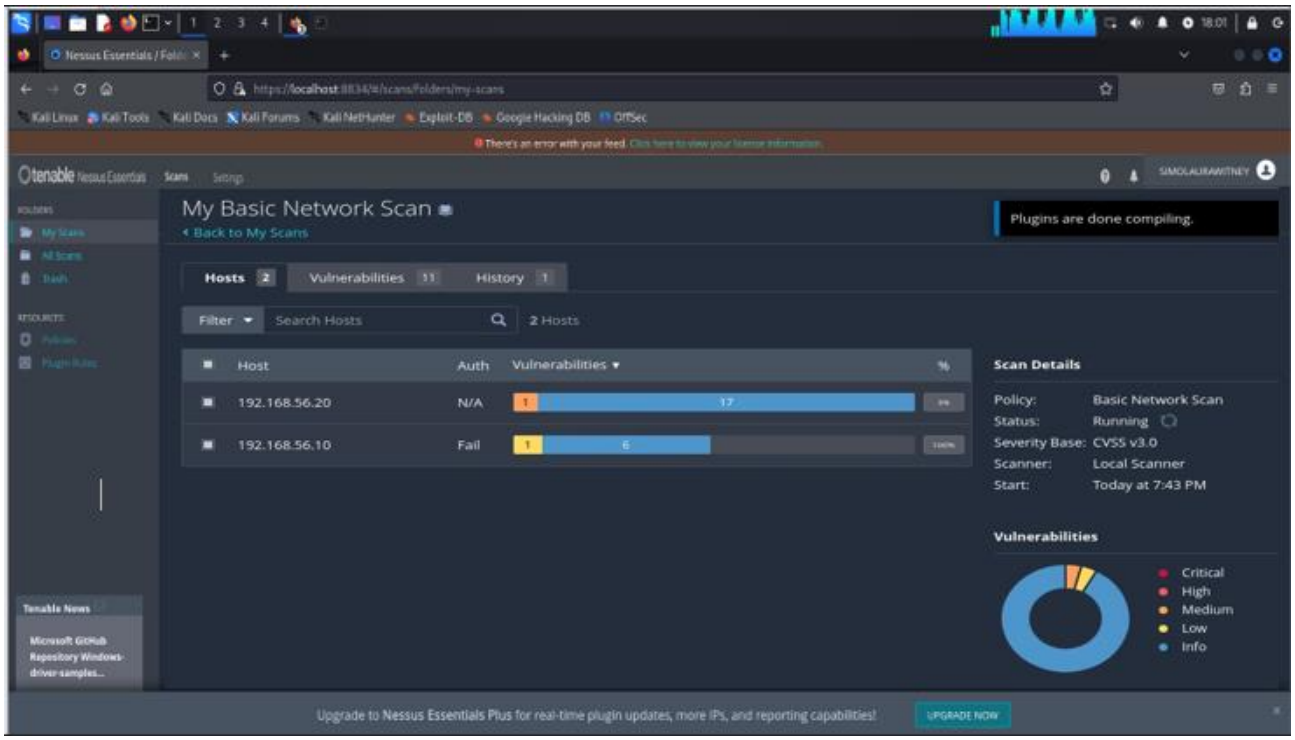
Un scan de type « Basic Network Scan » a été configuré pour analyser en profondeur les services, les ports ouverts et les mauvaises configurations logicielles.

Cibles : 192.168.56.10, 192.168.56.20

II-Analyse des Résultats

Synthèse globale

Le tableau de bord montre un total de 20 vulnérabilités. La majorité des alertes concernent la machine Windows, ce qui est cohérent avec un environnement de test où le pare-feu et les mises à jour automatiques sont souvent désactivés.



D'après la figure ci-dessus, on peut voir sur cette image qu'en ce qui concerne l'hôte 192.168.56.20 (Windows) on a une vulnérabilité critique, 0 haute, une moyenne, une faible et 31 infos. Par contre pour l'hôte 192.168.56.10(Ubuntu) on a une vulnérabilité faible et 30 infos.

Analyse des vulnérabilités « Medium »

L'analyse révèle des vulnérabilités de niveau Medium (CVSS 6.8). Ces failles permettent souvent à un attaquant de récupérer des informations sensibles sur le système ou de préparer une intrusion plus profonde.

Observation : Les failles détectées concernent principalement les protocoles de partage de fichiers et les services réseau Windows.

III-Recommandations et Remédiation

Pour sécuriser le parc informatique analysé, les mesures suivantes doivent être prises :

- Mises à jour système : Installer les derniers correctifs de sécurité (patches) suggérés par Nessus dans le détail des vulnérabilités.
- Hardening (Durcissement) : Désactiver les services inutilisés sur la machine Windows pour réduire la surface d'attaque.
- Configuration réseau : Réactiver le pare-feu Windows en ne laissant passer que les flux strictement nécessaires au TP.

Conclusion

Ce TP a permis de comprendre le cycle de vie d'un audit : de la découverte des hôtes à l'interprétation des failles. Nessus s'est révélé être un outil puissant pour transformer des données brutes en un plan d'action de sécurisation concret.